

The Guide to Cyber Incident Response Planning

Contents:

Introduction	3
Creating a Cyber Response Plan	6
Chapter 1: Preparation	8
Chapter 2: Identification	10
Chapter 3: Containment	12
Chapter 4: Eradication	13
Chapter 5: Recovery	15
Chapter 6: Lessons Learned	16
Chapter 7: Your Business' Reputation	18
Conclusion	19

Introduction

On a global scale, the average cost of a data breach is an estimated \$3.86 million in 2020.

Cybercrime is a frequent occurrence in today's world. Hackers attack every 39 seconds, meaning that a cyber attack takes place 2,244 times a day. And these attacks are not just a threat to large companies - 43% of breach victims in 2020 were small businesses.

In spite of the intensity of attacks, 77% of security and IT professionals worldwide indicate that they do not have an incident response plan applied consistently throughout the company. This may negatively impact the amount of time it takes to identify and contain a breach, which in turn increases the cost of a breach. The average time to identify and contain a breach in 2020 is 280 days. However, research by the Ponemon Institute¹ indicates that a breach with a life cycle of under 200 days costs \$1.2 million less than one with a life cycle of more than 200 days.

The situation for businesses is further complicated by the challenges and increased vulnerabilities that have been brought on by the growing use of remote working across the globe.

According to research done by the Ponemon Institute¹, 76% of respondents whose companies have shifted to remote work expect that working from home could increase the time it takes to identify and contain a data breach. Additionally, 70% of respondents expect that remote working could increase the cost of a data breach.

Clearly there is a disconnect between businesses' experience and concern about cyber security threats, and their understanding and ability to implement effective preventative measures. The most significant barriers to good cyber security practices are typically:

- A lack of dedicated IT security staff, as well as difficulty recruiting cyber talent
- Insufficient planning for and response to cyber incidents
- A failure to identify weaknesses, or uncertainty about where to begin
- Under estimation of cyber security risks
- Limited understanding of their own cyber security posture

The reality of cybercrime is that it's more likely a case of when and how bad an incident will be for an organization, rather than if it will occur.

And while you cannot control when an attack will happen, you can limit its impact through effective preparation and a detailed incident response plan.



1: <https://www.ibm.com/security/digital-assets/cost-data-breach-report/#/pdf>

Common cyber threats

Three of the most common cyber threats to organizations are malware, phishing and ransomware.



Malware is malicious software, including viruses, spyware, trojans and worms, designed to access important information, take control of a person's computer or spy on them.



Phishing is the use of fraudulent emails to trick victims out of money or information, or into downloading malware. The emails will mimic individuals or organizations that the person knows and trusts. General phishing emails are usually sent to thousands of people and often have obvious warning signs. Spear phishing emails are more sophisticated and typically target specific people in an organization, such as the accounts payable department. Whaling is a type of spear phishing that targets high value individuals, such as CEOs.



Ransomware is a type of malware that locks down your computer or files until a ransom is paid. They usually gain access via a legitimate-looking email link or attachment and often ask for payment in cryptocurrencies. The recommended guidance is that ransoms should never be paid as there is no guarantee you will regain access and it could make you vulnerable to a second attack.



While every organization should prepare for cyber threats such as these, this is especially important if your business falls into one of the most at-risk industries for cybercrime: **healthcare, manufacturing, financial services, government agencies and education**. These industries are highly targeted for a number of reasons, including the personal data and intellectual property they hold, the amount of money they handle and the impact that their service disruption would have on a society or State.

Preparing for a cyber incident

It's important to first review preventative measures when looking to reduce the risk of a cyber attack. However, as previously mentioned, the likelihood of businesses experiencing a cyber incident is high, so effective risk management must also include a cyber incident response plan and team.

In this guide, you will find information to help your business prepare for and limit the impact of a cyber incident, including:

- How to create a cyber incident response plan
- How to use the PICERL methodology to map out the most effective incident response for your business
- How to protect your business' reputation during and following an incident
- Common legal consequences to consider following an incident
- With war stories from the NCC Group archive showing you real-life cyber attacks and how they were mitigated.



Creating a Cyber Incident Response Plan

Creating a cyber incident response plan may seem like a huge undertaking, especially if you don't have a dedicated IT and security team, or lack experience in cyber security. However, the good news is that once broken down into stages, the task becomes significantly more manageable.

At NCC Group, we recommend breaking the process into five steps:

1. Identify a methodology

There are many recognized incident response frameworks that can assist in the development of your plan. The National Institute of Standards and Technology (NIST), International Organization for Standardization (ISO) and the SANS Institute have all developed recognized standards and frameworks that can be used. Once you've decided which one is best for your business, you can use the methodology for defining, designing and managing your response plan.

PICERL Incident Response Methodology

The PICERL methodology was developed by the SANS Institute, experts in information security training, certification and research. Today, it is one of the most widely used incident response frameworks and regarded as an industry-leading standard. PICERL is an acronym that stands for:

Preparation

Identification

Containment

Eradication

Recovery

Lessons Learned

It is frequently used by enterprises and their cyber security consulting partners to map out a best-practice strategy to effectively prepare for and respond to cyber incidents, while minimizing damage and downtime. This is the method that we'll be explaining how to use to create your incident response plan over the next six chapters.

2. Identify your key stakeholders

Your key stakeholders will be those people who are responsible for enacting and maintaining your incident response plan, such as senior management and the IT department. This step is also a good opportunity to identify training and education needs for the future cyber incident response team (CIRT).

3. Identify your information assets

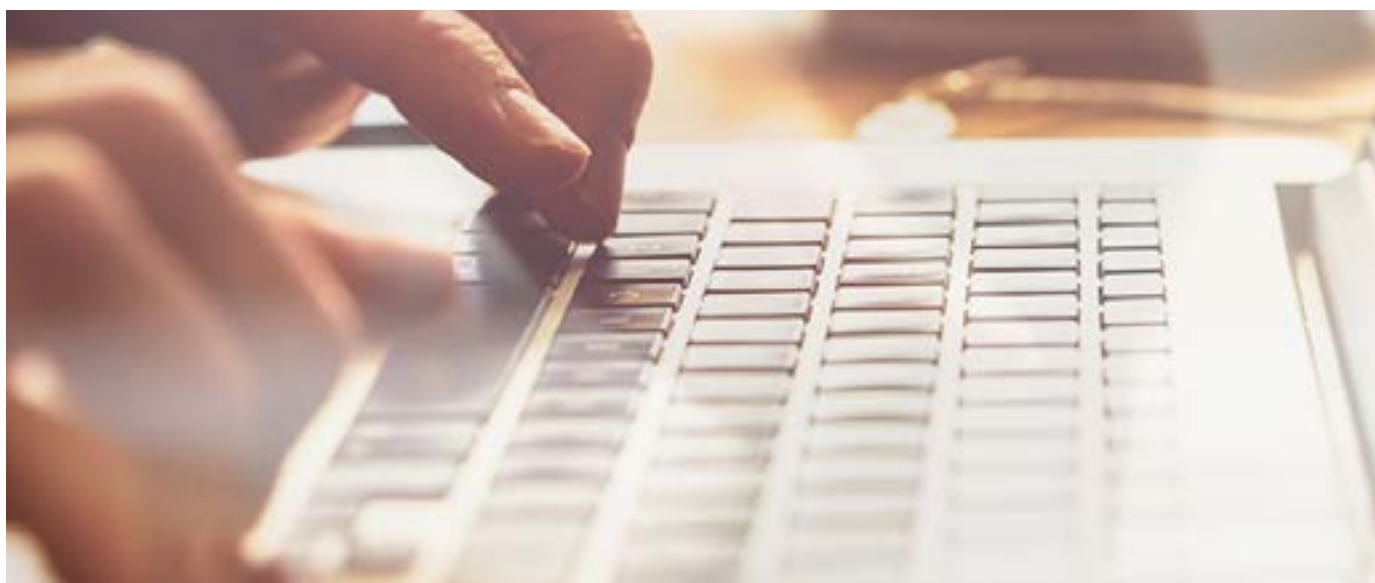
Identifying your assets will help you to understand what needs to be protected, where it is located, and any classification handling requirements or regulatory obligations that you need to abide by in the event of a data breach.

4. Identify your information and business processes

Understanding your business, technical and security processes will help you to capture and include tools that will implement your plan most effectively and reduce overheads during an incident response. You can also use this step to identify tooling that will help you manage an incident throughout its life cycle.

5. Develop and test policies and procedures

Bringing this all together in a well-crafted set of policies and procedures will help with effective management of an incident. Your incident response plan should be reviewed and tested regularly—at least once a year—to ensure that it remains fit-for-purpose, and that your incident response team is able to implement it effectively and efficiently. In the long run, this testing will help to reduce the impact of an incident to business operations, reduce the cost of incident recovery, and get your business back up and running faster.



Chapter 1:

PICERL - Preparation

The first phase in the PICERL methodology is Preparation—perhaps the most important part of responding effectively to a cyber incident. You wouldn't go on a holiday without first packing a suitcase, so why would you operate a business in today's threat landscape without first ensuring you've got everything in place to help you deal with cyber security incidents? It's an important first step and one companies shouldn't skimp on. The table below outlines the different areas you should consider when preparing for an incident.

Policy	Create a set of written policies, procedures, and processes that will guide the actions, responsibilities, and practices of individuals in your business with regards to cyber security. Policies and procedures should include topics such as a formal incident response plan, an acceptable use policy, and a data and log retention policy, just to name a few. Not only will these policies help to ensure a consistent approach across your organization, but it will also ensure that expectations are outlined clearly for all employees.
Response plan/strategy	Create a plan/strategy outlining how your response team will handle cyber incidents. An effective plan will prioritize potential incidents based on their organizational impact and then clearly define the most appropriate actions for dealing with them. For example, a single workstation going down may be a minor incident, while a human resources data breach may be a major incident. Additionally, if an incident response retainer exists, it's important that the internal response team knows exactly when they should engage external support.

Communication	There are two types of communication that are critical during a cyber incident—internal and external. Internal processes are essential for handling the incident itself, and the incident response team should know the correct people within the business to help triage an incident. External communication, such as public relations, must be clear and timely to protect public brand perception (see Chapter 8 for more information on this). Only those who have been properly trained in PR and crisis communications should be allowed to deal with the media. Another aspect to consider is when it is appropriate (or legally required) to involve law enforcement in an incident.
Documentation	The most significant reason for documenting an incident is that it may be used as evidence if the perpetrator of a cybercrime is prosecuted. However, even if this isn't possible, documentation is also important for the Lessons Learned phase of PICERL. Your incident response team should be prepared to document the who, what, where, when, how and why of every action they take when responding to an incident.
Team	Your cyber incident response team (CIRT) should be made up of a range of people to handle the various problems that arise during an incident, not just the technical ones. It may include attorneys, human resources, public relations and IT staff with specific specialties. Ensure that each person knows they are part of the response team, what their role will be and that they will be given access to the necessary tools and resources they need when an incident occurs.
Tooling	It is essential that your response team has the appropriate hardware, software and licensing to respond to a cyber threat, and that these are immediately available in the case of an incident. Establish the tools that your team will need, such as memory analysis, log parsers, anti-malware, screwdrivers, USB drives, checklists and contact lists, and then prepare a 'jump bag' that is ready to go as soon as an incident occurs.
Training	Ongoing cyber security training is a central pillar supporting your cyber incident response plan. Training techniques, including information sessions and attack simulation, are essential if your response team is to remain calm and collected during an incident. This shouldn't only be limited to technical skills though, as your PR, privacy and legal teams may also require specific crisis and cyber security training. It might also be necessary to engage an external incident response team on a retainer where certain skills are hard to find or sophisticated attacks are a threat.

Chapter 2:

PICERL - Identification

Phase 2 of PICERL is Identification. When there is a deviation from normal processes, it's necessary to identify if this is a simple event or an incident, a mistake or an attack. If the event is determined to be a cyber incident, it should be reported as soon as possible to allow the response team enough time to gather evidence on the source and scope of the threat, and enact their incident response plan.

Sometimes establishing the source is easy, even if it takes time—perhaps an employee clicked on a compromised link in an email only to be struck by ransomware. Often, though, it is a difficult and complex process to understand exactly what happened and how. Whatever the case, it will likely involve gathering information from a variety of places, including log files, error messages, data traffic anomalies, unusual activity, new access permissions, third-party supplier integrations, intrusion detection systems and firewalls.

Examples of how an incident may begin:

- An employee contacts the help desk to report that their system is acting strangely
- Intrusion detection systems report unusual network traffic
- Unusual activity in system logs
- A missing USB drive or other storage media

In this early stage of the incident life cycle, the response team should work to identify the who, what, where, when and how of the incident. The SANS Institute recommends that a minimum of two handlers be assigned to an incident, one to identify and assess the situation, and the other to gather evidence. Additionally, this is the time to designate a command center and communication lines between CIRT members.



Red flags in cyber security

1. **Unusual processes:** Processes are designed to ensure that data remains safe from threats while being used for normal business activities. If your established processes go awry, then it could indicate that something may be wrong, potentially signaling a malicious action.
2. **Abnormal security events:** As with odd processes, an out-of-the-ordinary security event could reveal a point of unauthorized entry into an organization's network and systems.
3. **Odd files:** Unusual files and registry keys could be a marker of something suspicious going on in your business' IT systems.
4. **New accounts or permissions:** Network and system administrators are well positioned to keep an eye out for accounts or permissions that were inexplicably created prior to an incident or event. Any such new accounts or permissions are worth a closer look as they may point responders to the source of an incident.
5. **Weird traffic flows:** Deviations from normal networks traffic flows, such as new traffic from certain hosts, could indicate a source of malicious activity. These deviations can be picked up by network administrators or intrusion detection systems, which in turn, can alert responders.

Once the scope of the incident is determined and evidence documented, the response team can move forward to Phase 3: Containment.



Chapter 3:

PICERL - Containment

The third phase of the PICERL methodology is Containment, where responders focus on limiting the damage caused by an incident and implementing measures to prevent further damage from occurring. Early detection and identification of incidents during the previous phase are key factors influencing the success of containment and, eventually, eradication of the threat. If done correctly, this phase will help your business get back up and running after being hit by a cyber incident, while still finishing the full incident response process.

The containment phase can be broken down into three steps: short-term containment, system backup and long-term containment.

1. Short-term containment

Just like the role of First Aid in the world of medical care, short-term containment is not intended to be a long-term solution to an immediate problem. Rather, it is a first step designed to stem the bleeding, so to speak—that is, to limit the effects of the incident before it gets worse.

Simply powering down an affected server or isolating a network could constitute effective short-term containment activities, as would removing LAN cables or quarantining affected computers to prevent tainted data traffic from infiltrating the broader enterprise network.

2. System backup

Before responders can wipe and re-image affected systems, a forensic image of the systems needs to be taken. This snapshot offers a clearer picture of precisely what was going on during the incident itself and provides responders with the information they need to fix and remediate the issue.

This step also provides valuable evidence in the event that the incident was the result of a criminal act. Additionally, the forensic image often plays a major role in working out how the affected systems were compromised—a key aspect of the final PICERL phase: Lessons Learned.

3. Long-term containment

Whereas short-term containment is about limiting the effects of the immediate problem, long-term containment involves preventing any further escalation of an incident while also allowing normal operation to continue. Depending on the severity of the issue, this may include complete remediation of the root cause of the incident.

Long-term containment typically includes activities such as patching affected and neighboring systems, removing backdoors left by attackers and removing user accounts found to have been employed in an attack.

Chapter 4:

PICERL -

Eradication

The eradication phase involves the removal of the threat from your business' IT infrastructure, as well as restoration of the affected systems. There are a few primary goals that response teams will want to achieve in this phase. They include determining the cause of the incident, as well as its symptoms, removing attackers' artifacts from affected systems, and improving defenses to help prevent the same or a similar incident from happening again in the future.

A triage process will often help to determine what level of eradication is required. For some incidents, the removal of a virus by a good antivirus solution may suffice. However, if the incident is complex, then a more thorough and foolproof approach is needed, such as a complete re-imaging of your systems' hard drives, followed by identifying and mitigating the exploited vulnerabilities.

It is critical that the threat to your data, networks and systems is completely eliminated and your infrastructure 'cleaned', before it is restored to normal, otherwise the incident may repeat itself.

Some of the eradication steps that your incident response team is likely to focus on include:

Root cause analysis

Root cause analysis aims to identify the primary source of a problem, which in cyber security means using a structured, defined approach to identify the underlying causes of an incident. This process should enable your response team to identify what happened, why it happened and what needs to be done to prevent or reduce the likelihood of it happening again.

Malware removal

Removing the malicious software an attacker has lodged in an organization's systems is a core element of eradication. Antivirus software can be used in this step to identify and remove known malware. A more thorough solution for complex threats is a full-blown wipe and re-imaging of affected drives.

Artifact deletion

Even if malware has been removed, it is likely that there will still be artifacts from a cyber intrusion in your system—digital remnants left over from an incident that may or may not seem relevant to the response process. For normal systems operation to return, these artifacts need to be identified and removed.

Backdoor closure

As with artifacts and malware, backdoors left by attackers need to be removed from the affected systems, as should any accounts created by attackers while they had access to your internal networks, systems or machines. It's not always easy to spot illicit backdoors, so it's important to spend some time on this step.

Patching

Software patching—updates, fixes or improvements to a program—should be done as a matter of course, but after a cyber incident it's vital to patch all affected and neighboring systems with the latest software updates. Not only will this harden internal systems against similar attacks, it will also help to protect them from other types of attacks.

While this is by no means an exhaustive list of the steps a response team might take to eradicate a threat, it is illustrative of the types of actions that require attention following an incident. Broadly, these are all designed to ensure systems are clean before any restoration, reformatting or re-imaging work begins.

Cyber Incident War Story from the NCC Group Archives

The finance team in an organization was targeted with phishing emails containing a malware attachment. Once one person clicked on the attachment, the malware downloaded to their computer and started logging keystrokes at that workstation. Eventually, the attacker got hold of bank credentials and transferred a large amount of money out of the account.

An NCC Group CIRT team was called in to investigate and was able to identify the source of the incident, remove the malware and help with security awareness training for the team to reduce the likelihood of them falling victim to another attack in the future.



Chapter 5:

PICERL -

Recovery

Phase 5 - Recovery focuses predominantly on when and how best to bring affected systems back in use. Ideally, this should be done with great care so as to avoid another potential incident due to the same issues that caused the initial problem. Incident response teams need to ensure that the systems aren't being reinfected by malware or compromised in another way during the recovery process.

For this reason, monitoring and testing plays a critical role during this phase. Response teams should carefully consider what system monitoring and testing activities are to be conducted once affected systems are back in use, as well as how long they should be monitored before they're deemed safe from another incident.

In this phase, response teams should consider:

- **When to restore:** Ultimately, system operators need to make the call as to when to restore affected systems, in conjunction with advice and consultation provided by the incident response team.
- **How to restore:** System operators need to decide whether to restore from a good, trusted backup, for example, or rely on re-imaging a system. Additionally, they may choose to restore a system with additional security controls in place, such as an intrusion prevention system or web application firewall.
- **How to test:** Incident response teams need to choose the most appropriate tools to test, monitor and verify that affected systems are fully functional and behaving normally, while also identifying recurrent issues if they arise.

- **How long to monitor:** Not only do responders need to decide which tools are best to monitor affected systems, they also have to determine how long a system should be kept under scrutiny to identify abnormal behavior.

The recovery phase represents the return to normal business operations following an incident. If everything goes well, your affected systems and associated processes should be back up and running as usual.

Chapter 6:

PICERL -

Lessons Learned

Once all affected systems are back in use and there are no signs of reinfection or other issues, the system operator and response team can turn to the Lessons Learned phase. Without this final PICERL phase, your business won't be able to effectively strengthen your cyber security posture following an incident.

In fact, learning is perhaps the single most valuable thing an organization can get out of a cyber security incident.

Having processes in place to learn from an incident has the potential to turn a business into a leader when it comes to information security—but only if those learnings are taken onboard and improvements implemented.

It's best practice to hold your Lessons Learned meeting within two weeks of the cyber incident, while the event is still fresh in everyone's mind. However, that doesn't mean the phase should be rushed, and there is value in spending time in this step ensuring that nothing is missed, and all associated documentation is clear and comprehensive.

Cyber Incident War Story from the NCC Group Archives

One NCC Group client identified that someone was using an internal email address to send spam messages to everyone in the organization. An NCC Group CIRT team was called in to help contain the situation. At the time, the attacker still had access to network credentials. The CIRT team worked with the client to reset the passwords of everyone potentially affected and implemented multi-factor authentication. Everyone was logged out of their account, effectively kicking the attacker out of the system and preventing them from re-accessing it.

They were also able to identify the attacker's entry point as a phishing email that requested an employee to enter their credentials. Once the attacker had these credentials, they were able to send more phishing emails that appeared even more legitimate as they came from an internal IP address.

The organization was able to learn from the incident the importance of multi-factor authentication and cyber security training for their employees.

Indeed, much of this phase is focused on good documentation, as this is the time when all the documentation generated during and following the incident should be compiled into a final report. This can be used as the basis for improving prevention, detection and response activities for possible future incidents.

Ideally, the final report of the incident and response effort should be able to answer core questions such as who, what, where, why and how, along with a chronological review of the entire incident and response.

The steps that need to be undertaken to ensure organizations and their teams learn from cyber incidents and use those learnings to improve their prevention, detection and incident response processes include:

1. Documenting the incident

Just like the role of First Aid in the world of medical care, short-term containment is not intended to be a long-term solution to an immediate problem. Rather, it is a first step designed to stem the bleeding, so to speak—that is, to limit the effects of the incident before it gets worse.

Complete the documentation of the incident and create any additional documentation that could benefit response efforts in the event of future incidents.

2. Compiling the report

Compile all documentation into a report that outlines what happened, what was done, and by whom. It should be able to answer the inevitable ‘who, what, where, why and how’ questions that are likely to arise during the Lessons Learned meeting.

3. Lessons Learned meeting

This meeting provides an opportunity for all the affected parties—response team, other parties, stakeholders—to review the incident response report together, provide feedback and share suggestions for areas of improvement.

4. Sharing the report with stakeholders

Once the report is finalized, including the takeaways from the meeting, share it with relevant stakeholders in your business. Given that the report should include recommendations to improve prevention, detection and incident response performance, this gives everyone a chance to understand what needs to be done.

5. Addressing processes

The final report offers numerous opportunities for your business and incident response team to tighten up your processes and be better prepared for an incident in the future.

6. Updating procedures

Similarly, the report will provide your business with guidance around which procedures need to be amended to improve response efficiency and efficacy.

The Lessons Learned phase brings an end to the PICERL methodology for incident response planning. However the process of establishing and maintaining a strong incident response should be ongoing, with your plan reviewed and practiced at least annually.

While planning and preparing for the unexpected is a significant challenge for most businesses and their IT teams today, a clear and comprehensive incident response plan can help you to minimize the impact of a bad situation and dramatically improve the time it takes you to return to business as usual. Not to mention, keeping your brand from negative public sentiment, which we'll address in the next chapter.

Chapter 7:

Your business' reputation

The financial and reputational damage from a data breach or cyber security incident can be substantial. When handled well, however, the incident can provide an opportunity for businesses to demonstrate leadership, forward thinking and sophistication in their information security posture.

In fact, if well managed, your business could even emerge from an incident with a stronger public trust profile than before as, by and large, it's how your organization responds to the breach that influences public perception. By preparing well and adopting best practices for incident response planning and execution (such as the PICERL method), your business can take charge of the situation, drive the solution and protect your brand in the public sphere.

Entities that have done this successfully respond quickly to the incident, prioritizing transparency with their stakeholders and the public. By communicating what measures, they are taking to contain and eradicate the threat, as well as adequately protect their (as yet) non-affected systems, they can maintain public confidence in their brand. Through a proactive plan that adheres to industry best practices, businesses can demonstrate their incident preparedness, thus avoiding the appearance of being a 'leaky bucket'.

Cyber Incident Communications

- Communicate early and clearly
- Prioritize transparency
- Demonstrate that you're following a best practice incident response plan
- Share the preventative measures you've taken to protect your unaffected systems
- Take ownership of the situation and drive the solution

Conclusion:

What next?

In today's threat landscape, it is a matter of when an organization will face a cyber incident rather than if they will. For that reason, it is critical that businesses not only implement preventative cyber security measures, but also prepare an incident response plan to guide them through a cyber attack.

Using an incident response framework, such as the PICERL methodology, will ensure that you can effectively identify, contain and eradicate a threat, with minimal damage and downtime for your business.

However, as many organizations also face the additional challenges of limited IT staff and cyber security expertise, **outsourcing elements of cyber security management is a more effective and efficient way to protect your business.** You get access to experts who handle cyber incidents day-in-day-out and in a variety of industries. They're on call 24/7 and cover everything from planning, training, incident response and mitigation, Media & PR support and regulatory and privacy advice.

To learn more about the emergency and retainer cyber incident response support that NCC Group offers, [click here](#).



24/7, 365 hotline



Phone response
<1 hour*



Regular threat intel
meetings*



First responder training*



Detailed onboarding =
efficient response

*for silver and gold tiers

About us

NCC Group exists to make the world safer and more secure.

As global experts in cyber security and risk mitigation, NCC Group is trusted by over 14,000 customers worldwide to protect their most critical assets from the ever-changing threat landscape.

With the company's knowledge, experience and global footprint, it is best placed to help organizations assess, develop and manage their cyber resilience posture.

To support its mission, NCC Group continually invests in research and innovation, and is passionate about developing the next generation of cyber scientists.

With circa 2,000 colleagues in 12 countries, NCC Group has a significant market presence in North America, Europe and the UK, and a rapidly growing footprint in Asia Pacific with offices in Australia, Japan and Singapore.

Get in touch

T: 1 (800) 813 3523

E: uscons-info@nccgroup.com

W: <https://www.nccgroup.com>

